

Marco Integrativo GQM + PRAGMATIC para Indicadores TRIKE

1. Introducción

Este documento integra el enfoque Goal–Question–Metric (GQM) con los criterios PRAGMATIC para el conjunto de indicadores propuestos en el informe TRIKE a escala nacional (España) y comparativa internacional. [web:23][web:38][web:39][web:42][web:45]

El objetivo es garantizar la trazabilidad desde los objetivos estratégicos nacionales (p.ej. NIS2, Ley de Coordinación y Gobernanza de la Ciberseguridad) hasta los datos técnicos concretos que se recogen, calculan y reportan. [web:16][web:41][web:44]

2. Resumen del enfoque GQM aplicado a TRIKE

- Goal (Objetivo): qué se pretende lograr en cada dimensión TRIKE (Threat, Risk, Impact, Knowledge, Evaluation) a nivel país/sector/organización.
- Question (Pregunta): qué hay que preguntar para saber si avanzamos hacia ese objetivo.
- Metric (Métrica): qué medimos, de forma concreta y cuantificable, para responder a la pregunta. [web:38]

En este contexto:

- Los objetivos se alinean con las obligaciones de gestión de riesgos y resiliencia definidas en NIS2 y la guía técnica de ENISA. [web:23][web:43]
- Las preguntas se derivan del informe TRIKE y de las prácticas recomendadas por ENISA e ISACA para programas de ciberseguridad basados en amenazas. [web:14][web:25][web:46]
- Las métricas permiten conectar la macrovisión nacional con la microrealidad técnica (incidentes, vulnerabilidades, tiempos de respuesta, etc.).

3. PRAGMATIC: criterios de calidad de las métricas

Los criterios PRAGMATIC (Predictive, Relevant, Actionable, Genuine, Meaningful/Significativo, Accurate/Preciso, Timely/Oportuno, Independent/Independiente, Cheap/Rentable) se utilizan para evaluar la calidad de cada métrica propuesta. [web:39][web:42][web:45][web:47]

Cada métrica se puntúa en una escala de 0 a 5 por criterio, donde:

- 0 = el criterio no se cumple en la práctica.
- 1–2 = cumplimiento débil o limitado.
- 3–4 = cumplimiento razonable / bueno.
- 5 = cumplimiento excelente.

La combinación de GQM + PRAGMATIC permite:

1. Asegurar que no medimos nada que no responda a un objetivo claro.
2. Priorizar las métricas que realmente aportan valor (alto score PRAGMATIC).
3. Evitar proliferación de métricas “baratas pero estériles” que consumen recursos sin mejorar decisiones.

4. Objetivos, preguntas y métricas por dimensión TRIKE

A continuación se resumen los principales objetivos GQM y las métricas asociadas para cada dimensión TRIKE. El detalle PRAGMATIC se desarrolla en el documento de Matriz de Evaluación. [web:23][web:38]

4.1 Threat (Amenaza)

Goal T1: Mejorar el conocimiento y la monitorización de la intensidad y naturaleza de las amenazas que afectan a los sectores esenciales en España, en línea con NIS2 y los informes de amenaza europeos. [web:23][web:43][web:46]

- Question T1.1: ¿Cuál es la frecuencia y distribución de incidentes de ciberseguridad en España por sector y tamaño de organización?
- Metric T1.1.a: Número de incidentes de ciberseguridad por 100.000 habitantes y por sector crítico, según datos de INCIBE, CCN-CERT y otros CSIRTs sectoriales. [web:22][web:46]
- Metric T1.1.b: Número de incidentes significativos reportados en el marco NIS2 por tipo de entidad esencial/importante. [web:23][web:44]
- Question T1.2: ¿Cuál es el peso relativo de distintos tipos de amenazas (APT, ransomware, ataques sin malware, etc.)?
- Metric T1.2.a: Porcentaje de incidentes atribuidos a actores avanzados (APT, eCrime organizado) frente a amenazas oportunistas. [web:13][web:46]
- Metric T1.2.b: Porcentaje de detecciones “malware-free” y ataques asistidos por IA sobre el total de incidentes detectados en el periodo. [web:13][web:46]
- Question T1.3: ¿En qué medida se explota la cadena de suministro y los servicios cloud como vectores de ataque?
- Metric T1.3.a: Número de incidentes derivados de proveedores de servicios esenciales (cloud, telecomunicaciones, SaaS) por año. [web:23][web:43]
- Metric T1.3.b: Porcentaje de vulnerabilidades explotadas relacionadas con cadena de suministro software (incluyendo componentes de terceros y dependencias de código). [web:23][web:46]

Metric T1.1.b: Número de incidentes significativos reportados en el marco NIS2 por tipo de entidad esencial/importante. [web:23][web:44]

Question T1.2: ¿Cuál es el peso relativo de distintos tipos de amenazas (APT, ransomware, ataques sin malware, etc.)?

Metric T1.2.b: Porcentaje de detecciones “malware-free” y ataques asistidos por IA sobre el total de incidentes detectados en el periodo. [web:13][web:46]

Question T1.3: ¿En qué medida se explota la cadena de suministro y los servicios cloud como vectores de ataque?

4.2 Risk (Riesgo)

Goal R1: Asegurar que los riesgos de ciberseguridad se cuantifican y gestionan de forma consistente con NIS2, integrando probabilidades, impactos económicos y criterios de apetito de riesgo. [web:23][web:16]

- Question R1.1: ¿Cuál es el riesgo económico anual esperado derivado de ciberincidentes por sector?
- - Metric R1.1.a: Pérdida económica anual esperada (en euros) por cada 1.000 millones de valor añadido sectorial (basada en frecuencia e impacto de incidentes). [web:16][web:23]
- - Question R1.2: ¿Hasta qué punto se integra el análisis de riesgo en la definición de presupuestos y medidas de seguridad?
- - Metric R1.2.a: Porcentaje de entidades que reportan utilizar métricas de riesgo cuantitativo (FAIR u otros) para decisiones de inversión. [web:25]
- - Question R1.3: ¿Cómo se distribuye el riesgo entre pymes, grandes empresas y sector público?
- Metric R1.3.a: Ratio incidentes significativos / número de entidades por categoría. [web:16][web:22]
- Metric R1.3.b: Estimación de pérdida media por incidente por tipo de entidad. [web:22]

Metric R1.1.a: Pérdida económica anual esperada (en euros) por cada 1.000 millones de valor añadido sectorial (basada en frecuencia e impacto de incidentes). [web:16][web:23]

Question R1.2: ¿Hasta qué punto se integra el análisis de riesgo en la definición de presupuestos y medidas de seguridad?

Metric R1.2.a: Porcentaje de entidades que reportan utilizar métricas de riesgo cuantitativo (FAIR u otros) para decisiones de inversión. [web:25]

Question R1.3: ¿Cómo se distribuye el riesgo entre pymes, grandes empresas y sector público?

4.3 Impact (Impacto)

Goal I1: Comprender el impacto operacional, económico y social de los incidentes para orientar la resiliencia y la continuidad de negocio a nivel nacional. [web:23][web:16]

- Question I1.1: ¿Cuál es la duración típica de interrupciones en servicios esenciales por incidente significativo?
- - Metric I1.1.a: Duración media (y máxima) de la indisponibilidad de servicios críticos, en horas. [web:23]
- - Question I1.2: ¿Cuál es la magnitud económica del impacto de los incidentes?
- - Metric I1.2.a: Coste económico medio de incidentes significativos por sector. [web:22]
- - Metric I1.2.b: Percentiles de impacto (p.ej. P90, P95) para incidentes graves. [web:23]
- - Question I1.3: ¿Cuál es el impacto social y reputacional agregado?
- - Metric I1.3.a: Número de usuarios/ciudadanos afectados por incidentes reportados (por sector). [web:22]
- - Metric I1.3.b: Número de sanciones regulatorias y su cuantía anual (NIS2, RGPD, sectoriales). [web:44]

Metric I1.1.a: Duración media (y máxima) de la indisponibilidad de servicios críticos, en horas. [web:23]

Question I1.2: ¿Cuál es la magnitud económica del impacto de los incidentes?

Metric I1.2.b: Percentiles de impacto (p.ej. P90, P95) para incidentes graves. [web:23]

Question I1.3: ¿Cuál es el impacto social y reputacional agregado?

4.4 Knowledge (Conocimiento)

Goal K1: Incrementar la capacidad del país para generar, compartir y utilizar inteligencia de amenazas, lecciones aprendidas y talento especializado. [web:16][web:25][web:40]

- Question K1.1: ¿Cuál es el nivel de implantación de programas de inteligencia de amenazas?
- - Metric K1.1.a: Porcentaje de entidades esenciales/importantes que declaran disponer de un programa formal de threat intelligence (propio o de terceros). [web:25][web:40]
- - Question K1.2: ¿En qué medida se documentan y reutilizan las lecciones aprendidas?
- - Metric K1.2.a: Porcentaje de incidentes significativos que generan un informe post-mortem formal (lecciones aprendidas, acciones de mejora). [web:25][web:23]
- - Question K1.3: ¿Cuál es la disponibilidad de talento en ciberseguridad?
- - Metric K1.3.a: Número de profesionales de ciberseguridad certificados por 100.000 habitantes. [web:16]
 - Metric K1.3.b: Ratio vacantes abiertas / puestos cubiertos en roles críticos de ciberseguridad según ECSF. [web:40]

Metric K1.1.a: Porcentaje de entidades esenciales/importantes que declaran disponer de un programa formal de threat intelligence (propio o de terceros). [web:25][web:40]

Question K1.2: ¿En qué medida se documentan y reutilizan las lecciones aprendidas?

Metric K1.2.a: Porcentaje de incidentes significativos que generan un informe post-mortem formal (lecciones aprendidas, acciones de mejora). [web:25][web:23]

Question K1.3: ¿Cuál es la disponibilidad de talento en ciberseguridad?

4.5 Evaluation (Evaluación)

Goal E1: Garantizar que las medidas de seguridad se evalúan y mejoran continuamente, alineadas con los requisitos de supervisión y cumplimiento de NIS2. [web:23][web:43]

- Question E1.1: ¿Con qué frecuencia y profundidad se evalúan los controles de seguridad y los modelos de riesgo?
- Metric E1.1.a: Porcentaje de entidades que realizan revisiones al menos anuales de modelos de amenaza y controles clave. [web:23][web:43]
- Question E1.2: ¿Hasta qué punto se cumplen los requisitos de NIS2 y su transposición española?
- Metric E1.2.a: Porcentaje de entidades que declaran alto grado de alineamiento con las medidas de gestión de riesgos exigidas por NIS2. [web:17][web:44]
- Metric E1.2.b: Número de hallazgos de supervisión/auditoría por categoría (gobernanza, gestión de incidentes, cadena de suministro, etc.). [web:43][web:44]
- Question E1.3: ¿Se utilizan los resultados de evaluación para reorientar recursos y prioridades?
- Metric E1.3.a: Porcentaje de entidades que vinculan explícitamente resultados de auditoría/supervisión a cambios presupuestarios y de roadmap de seguridad. [web:16][web:41]

Metric E1.1.a: Porcentaje de entidades que realizan revisiones al menos anuales de modelos de amenaza y controles clave. [web:23][web:43]

Question E1.2: ¿Hasta qué punto se cumplen los requisitos de NIS2 y su transposición española?

Metric E1.2.b: Número de hallazgos de supervisión/auditoría por categoría (gobernanza, gestión de incidentes, cadena de suministro, etc.). [web:43][web:44]

Question E1.3: ¿Se utilizan los resultados de evaluación para reorientar recursos y prioridades?

5. Integración en el ciclo TRIKE nacional

Cada métrica propuesta puede recogerse mediante encuestas (autodeclaración), datos administrativos (INCIBE, CCN-CERT, autoridades competentes) y estudios de mercado. [web:16][web:22][web:46]

El ciclo recomendado es:

4. Definir objetivos nacionales y sectoriales (Goals).
5. Formular preguntas operativas que permitan evaluar el avance (Questions).
6. Seleccionar métricas con alto valor PRAGMATIC (Metrics).
7. Recoger y consolidar datos anualmente.
8. Revisar el set de métricas cada 2–3 años a la luz de nuevas amenazas, regulaciones y capacidades.